Аудит ответов финансового API

Дата проверки	10 октября 2026 г. в 21:09:55 GMT+3
Данные	живые ответы API — сырые ответы в `snapshot.json`
Итог	🔴 критичных: 0 · 🟡 предупреждений: 2 · 🔵 к сведению: 6

Резюме

Сейчас API отдаёт данные, по которым выручка считается корректно: критичных проблем нет, все эндпоинты отвечают за ~1 с.

Главное к исправлению: все 9 строк `GET /finance2` содержат код валюты в нижнем регистре (`"300 usd"`, `"200 eur"`), тогда как `GET /finance1` отдаёт `"USD"` / `"EUR"`. Наш клиент приводит регистр сам, поэтому цифры верные, но это нарушение ISO 4217 и контракта: любой потребитель со строгим сравнением (`=== "USD"`) получит ошибку или посчитает `usd` и `USD` как две разные валюты.

Рекомендации по контракту (не ломают расчёт сейчас, но мешают сверке): у транзакций `/finance1` нет `id` и даты оплаты; `/finance2` отдаёт плоские строки без id, даты и статуса — формат отличается от `/finance1`; в `/finance1` приходит блок `address`, который к финансовым данным не относится.

Эндпоинты

Эндпоинт	HTTP	Время	Content-Type	Записей
GET /finance1	200	0.9 с	application/json; charset=utf-8	8
GET /finance2	200	0.9 с	application/json; charset=utf-8	9
GET /rates/latest (CurrencyFreaks)	200	1.1 с	application/json	1042

Сводка данных

- Статусы транзакций в /finance1: `paid` × 5, `pending` × 1, `rejected` × 2
- Оплаты /finance1 (`paid`) по валютам: 1 110,00 USD, 760,00 EUR
- Платежи /finance2 по валютам: 1 910,00 USD, 1 150,00 EUR

Проблемы в финансовом API

🟡 CUR-CASE — Код валюты не в верхнем регистре

Где: GET /finance2 · **Важность:** Предупреждение · **Найдено:** 9

Где	Значение	Комментарий
`[0]`	`"usd"`	ожидается "USD"
`[1]`	`"eur"`	ожидается "EUR"
`[2]`	`"usd"`	ожидается "USD"
`[3]`	`"usd"`	ожидается "USD"
`[4]`	`"eur"`	ожидается "EUR"

Где	Значение	Комментарий
`[5]`	`"usd"`	ожидается "USD"
`[6]`	`"usd"`	ожидается "USD"
`[7]`	`"usd"`	ожидается "USD"
…	ещё 1	полный список в `findings.json`

Влияние: Клиент нормализует регистр сам, поэтому расчёт верный. Но ISO 4217 требует верхний регистр, и любой другой потребитель API со строгим сравнением (`=== "USD"`) получит ошибку или разнесёт одну валюту на две.

Как исправить: Отдавать коды валют в верхнем регистре: `USD` , `EUR` .

🟡 CUR-INCONSISTENT — Одна валюта записана по-разному

Где: GET /finance1 + GET /finance2 · **Важность:** Предупреждение · **Найдено:** 2

Где	Значение	Комментарий
`USD`	`"USD" в finance1; "usd" в finance2`	
`EUR`	`"EUR" в finance1; "eur" в finance2`	

Влияние: Клиент приводит написание к одному виду, но потребитель без нормализации посчитает одну валюту как несколько.

Как исправить: Единый формат кода валюты во всех эндпоинтах.

🔵 F1-NO-DATE — У транзакций нет даты

Где: GET /finance1 · **Важность:** К сведению · **Найдено:** 1

Где	Значение	Комментарий
`transactions[*]`	`нет полей date / createdAt / paidAt / timestamp / time`	

Влияние: Клиент не может проверить, что все оплаты относятся к нужному дню.

Как исправить: Добавить дату оплаты в ISO 8601 (`2026-10-10T12:00:00Z`).

🔵 F1-NO-ID — У транзакций нет уникального идентификатора

Где: GET /finance1 · **Важность:** К сведению · **Найдено:** 1

Где	Значение	Комментарий
`transactions[*]`	`нет полей id / _id / transactionId / uuid`	

Влияние: Невозможно отличить дубль от двух одинаковых оплат и сверить данные с учётной системой.

Как исправить: Добавить `id` в каждую транзакцию.

🔵 F1-ROOT-EXTRA — В ответе есть поля, не относящиеся к транзакциям

Где: GET /finance1 · **Важность:** К сведению · **Найдено:** 1

Где	Значение	Комментарий
`body`	`address`	

Влияние: Клиент их игнорирует. Если это персональные данные — лишняя утечка наружу.

Как исправить: Убрать из финансового эндпоинта поля, которые не нужны для расчёта, или вынести в отдельный эндпоинт.

🔵 F2-STRUCTURE — Платежи — плоские строки без структуры

Где: GET /finance2 · **Важность:** К сведению · **Найдено:** 1

Где	Значение	Комментарий
`[*]`	`9 элементов вида "300 usd"`	

Влияние: Нет id, даты и статуса: нельзя сверить, отфильтровать неоплаченные или найти дубли. Форматы двух источников разные.

Как исправить: Отдавать объекты в том же формате, что и `/finance1`: `{ id, type, amount, currency, date }`.

Провайдер курсов CurrencyFreaks (к сведению)

Сторонний сервис, не входит в зону backend-команды. Приведено для полноты картины.

🔵 R-NON-ISO — В списке курсов есть не-ISO коды (криптовалюты, токены)

Где: GET /rates/latest (CurrencyFreaks) · **Важность:** К сведению · **Найдено:** 1

Где	Значение	Комментарий
`rates`	`882 кодов, из них 324 трёхбуквенных`	например: WLD, HNT, DGB, BCH, JST, HOT, SEI, JTO, DHN, FLR, BDX, SFP

Влияние: Трёхбуквенные тикеры (`BTC`, `ETH`, `SOL` …) проходят проверку формата — поэтому важна проверка `CUR-NOT-ISO` на стороне API.

Как исправить: Действий от провайдера не требуется; учитывать на стороне API/клиента.

🔵 R-VALUE-STRING — Курсы переданы строками

Где: GET /rates/latest (CurrencyFreaks) · **Важность:** К сведению · **Найдено:** 1

Где	Значение	Комментарий
`rates`	`1042 из 1042`	

Влияние: Клиент приводит к числу сам. Поведение задокументировано у провайдера.

Как исправить: Действий не требуется.

Проверки без замечаний

- ✅ `CUR-CASE` (GET /finance1) — Код валюты не в верхнем регистре
- ✅ `CUR-FORMAT` (GET /finance1) — Код валюты не из 3 латинских букв
- ✅ `CUR-MISSING` (GET /finance1) — Код валюты отсутствует или не строка
- ✅ `CUR-NO-RATE` (GET /finance1) — Для валюты нет курса у провайдера
- ✅ `CUR-NOT-ISO` (GET /finance1) — Код валюты не существует в ISO 4217
- ✅ `CUR-WHITESPACE` (GET /finance1) — Пробелы вокруг кода валюты
- ✅ `F1-AMOUNT-INVALID` (GET /finance1) — Сумма отсутствует или не конечное число

- ✅ `F1-AMOUNT-NEGATIVE` (GET /finance1) — Отрицательная сумма
- ✅ `F1-AMOUNT-PRECISION` (GET /finance1) — Больше 2 знаков после запятой
- ✅ `F1-AMOUNT-TYPE` (GET /finance1) — Сумма передана строкой, а не числом
- ✅ `F1-AMOUNT-ZERO` (GET /finance1) — Оплата на нулевую сумму
- ✅ `F1-DUPLICATE` (GET /finance1) — Полностью одинаковые оплаты
- ✅ `F1-EMPTY` (GET /finance1) — Список транзакций пуст
- ✅ `F1-EXTRA-FIELDS` (GET /finance1) — Неожиданные поля в транзакции
- ✅ `F1-RECORD-NOT-OBJECT` (GET /finance1) — Транзакция — не объект
- ✅ `F1-SHAPE` (GET /finance1) — Ответ не объект с массивом `transactions`
- ✅ `F1-TYPE-CASE` (GET /finance1) — Статус `paid` в другом регистре или с пробелами
- ✅ `F1-TYPE-MISSING` (GET /finance1) — У транзакции нет строкового `type`
- ✅ `F1-TYPE-UNKNOWN` (GET /finance1) — Неизвестный статус транзакции
- ✅ `HTTP-CONTENT-TYPE` (GET /finance1) — Content-Type не application/json
- ✅ `HTTP-JSON` (GET /finance1) — Тело ответа — не валидный JSON
- ✅ `HTTP-SLOW` (GET /finance1) — Ответ дольше 10 с
- ✅ `HTTP-STATUS` (GET /finance1) — Эндпоинт не вернул успешный ответ
- ✅ `CUR-FORMAT` (GET /finance2) — Код валюты не из 3 латинских букв
- ✅ `CUR-MISSING` (GET /finance2) — Код валюты отсутствует или не строка
- ✅ `CUR-NO-RATE` (GET /finance2) — Для валюты нет курса у провайдера
- ✅ `CUR-NOT-ISO` (GET /finance2) — Код валюты не существует в ISO 4217
- ✅ `CUR-WHITESPACE` (GET /finance2) — Пробелы вокруг кода валюты
- ✅ `F2-AMOUNT-FORMAT` (GET /finance2) — Сумма в строке в недопустимом формате
- ✅ `F2-FORMAT` (GET /finance2) — Строка не в формате `"<сумма> <ВАЛЮТА>"`
- ✅ `F2-ITEM-TYPE` (GET /finance2) — Элемент массива — не строка
- ✅ `F2-SHAPE` (GET /finance2) — Ответ — не массив
- ✅ `F2-WHITESPACE` (GET /finance2) — Лишние пробелы в строке платежа
- ✅ `HTTP-CONTENT-TYPE` (GET /finance2) — Content-Type не application/json
- ✅ `HTTP-JSON` (GET /finance2) — Тело ответа — не валидный JSON
- ✅ `HTTP-SLOW` (GET /finance2) — Ответ дольше 10 с
- ✅ `HTTP-STATUS` (GET /finance2) — Эндпоинт не вернул успешный ответ
- ✅ `HTTP-CONTENT-TYPE` (GET /rates/latest (CurrencyFreaks)) — Content-Type не application/json
- ✅ `HTTP-JSON` (GET /rates/latest (CurrencyFreaks)) — Тело ответа — не валидный JSON
- ✅ `HTTP-SLOW` (GET /rates/latest (CurrencyFreaks)) — Ответ дольше 10 с
- ✅ `HTTP-STATUS` (GET /rates/latest (CurrencyFreaks)) — Эндпоинт не вернул успешный ответ
- ✅ `R-DATE` (GET /rates/latest (CurrencyFreaks)) — Нет даты курсов или она в неожиданном формате
- ✅ `R-SHAPE` (GET /rates/latest (CurrencyFreaks)) — Ответ провайдера без `base` или `rates`
- ✅ `R-STALE` (GET /rates/latest (CurrencyFreaks)) — Курсы старше 36 ч
- ✅ `R-VALUE-INVALID` (GET /rates/latest (CurrencyFreaks)) — Нечисловые или неположительные курсы

Ожидаемый контракт

`GET /finance1`:

```
{ "transactions": [ { "type": "paid", "amount": 100.5, "currency": "USD" } ] }
```

- `type` — строка в нижнем регистре: `paid` | `pending` | `rejected`; в выручку идёт только `paid`.

- `amount` — число ≥ 0, не более 2 знаков после точки.
- `currency` — код ISO 4217, 3 латинские буквы в верхнем регистре.

`GET /finance2`:

```
["300 USD", "150.50 EUR"]
```

- Каждая строка — `"<сумма> <ВАЛЮТА>"`: сумма с точкой и ≤ 2 знаками, один пробел, код ISO 4217 в верхнем регистре.

Как воспроизвести

```
curl -H "x-api-key: $FINANCE_API_KEY" https://cpa-server-vtel.onrender.com/api/finance1
curl -H "x-api-key: $FINANCE_API_KEY" https://cpa-server-vtel.onrender.com/api/finance2
```